

CAHIER DES CHARGES

NEXUS SOC

Plateforme de Security Operations Center as a Service (SOCaaS)
souveraine pour la protection des organisations camerounaises contre les
cybermenaces internes

Auteur : NGUETSA Junior Stéphane Céleste

Établissement : KEYCE Informatique & Intelligence Artificielle — Yaoundé, Cameroun

Diplôme visé : Bachelor 3 — Réseaux et Systèmes Informatiques (RSI)

Structure d'accueil : Ministère des Finances (MINFI) — Cameroun

Période de stage : Mai – Juillet 2026

Document : Cahier des charges — Version 1.0

Document de référence définissant le contexte, le périmètre, les exigences fonctionnelles et non-fonctionnelles, les contraintes et les critères d'acceptation du projet.

Sommaire

1. Présentation générale du projet	3
2. Périmètre du projet	4
3. Exigences fonctionnelles	5
4. Exigences non-fonctionnelles	6
5. Contraintes	6
6. Stack technique	7
7. Modèles d'intelligence artificielle	7
8. Modèle économique	8
9. Critères d'acceptation et d'évaluation	8
10. Livrables et planning	9
11. Risques et hypothèses	9

1. Présentation générale du projet

1.1 Contexte

La transformation numérique de l'État et du secteur privé camerounais accroît mécaniquement leur exposition aux cybermenaces. Les **administrations publiques** — ministères, directions générales et agences d'État — concentrent des données particulièrement sensibles (fiscales, budgétaires, données des agents publics) et constituent des cibles de premier plan ; pourtant, elles disposent rarement d'une capacité de détection souveraine et adaptée à leur contexte. En parallèle, les structures financières **non bancaires** (établissements de microfinance, compagnies d'assurance, cabinets comptables) manipulent des données financières et clients critiques sans avoir les moyens d'un SOC interne — le recrutement d'un seul analyste de sécurité représentant un coût de l'ordre de 500 000 FCFA par mois, hors outillage.

1.2 Problématique

Faute de moyens de détection, ces organisations subissent des incidents (rançongiciels, intrusions réussies, hameçonnage, exfiltration de données, fraude interne) sans visibilité ni capacité de réaction. La question centrale est **double selon la cible** : comment doter une administration publique d'une capacité de détection et de réponse aux menaces internes qui soit **souveraine et conforme** au cadre réglementaire national ; et comment offrir à une structure financière non bancaire la même capacité sous une forme **clé en main et à un coût soutenable**, sans expertise interne en cybersécurité ?

1.3 Objectifs

Objectif général : concevoir et réaliser une plateforme SOCaaS automatisée, accessible par abonnement ou par contrat public, surveillant en continu le parc informatique d'organisations clientes.

Objectifs spécifiques :

- Collecter en continu la télémétrie des postes et serveurs via un agent léger et multiplateforme.
- Corréler les événements pour reconstituer des chaînes d'attaque multi-étapes (SIEM).
- Détecter les comportements anormaux par apprentissage automatique (UEBA) et par détection d'anomalies réseau.
- Automatiser la réponse aux incidents via des playbooks encadrés par des garde-fous (SOAR).
- Restituer l'information à un responsable non-technicien via un portail clair et des notifications.
- Garantir la souveraineté des données et la conformité au cadre réglementaire camerounais.

1.4 Proposition de valeur

NEXUS SOC joue le rôle d'une équipe d'analystes de sécurité disponible 24h/24, sans exiger d'expertise interne en cybersécurité. Son positionnement **souverain** (hébergement national, conformité locale) constitue un avantage différenciant majeur face aux solutions étrangères, en particulier pour les administrations et institutions financières.

1.5 Cibles et proposition de valeur différenciée

Le projet vise deux segments aux logiques d'achat distinctes ; l'argumentaire de valeur diffère donc selon la cible.

Cible	Profil	Argument de valeur dominant
Principale	Administrations publiques : ministères, directions générales, agences d'État	Souveraineté des données + conformité (ANTIC, loi n° 2010/012) + détection de la menace interne. Le prix n'est pas l'argument central.
Secondaire	Secteur financier non bancaire : microfinance, assurances, cabinets comptables	Service clé en main, automatisé et à coût soutenable, sans expertise interne requise.

➤ *Séquençement commercial : le secteur financier non bancaire constitue la porte d'entrée (cycle de vente court, chiffre d'affaires rapide) tandis que les contrats publics, plus longs à conclure, mûrissent en parallèle.*

2. Périmètre du projet

2.1 Menaces couvertes (menaces internes)

- Logiciels malveillants et rançongiciels actifs sur les postes.
- Intrusions déjà réussies (compromission de comptes).
- Comportements suspects d'utilisateurs internes (menace interne).
- Mouvements latéraux au sein du réseau.
- Exfiltration de données sensibles.
- Communications vers des serveurs de commande et contrôle (C2).
- Activité anormale en dehors des heures ouvrables.

2.2 Hors périmètre

- Protection périmétrique réseau active (pare-feu nouvelle génération, IPS en coupure) — NEXUS SOC observe et réagit, il ne remplace pas l'équipement réseau.
- Détection de fraude sur les services de paiement mobile (couche transactionnelle hors de portée d'un agent endpoint) — explicitement exclue du périmètre.
- Audit applicatif et test d'intrusion offensif.

➤ *Cette frontière est volontaire : elle garantit un projet réaliste et défendable, centré sur ce qu'un agent endpoint + un moteur de corrélation peuvent réellement observer.*

2.3 Périmètre fonctionnel complet et lots de réalisation

Le projet vise la réalisation de la **plateforme complète** : l'ensemble des composants et des capacités décrits ci-dessous constituent le périmètre à livrer. Pour en maîtriser la complexité, la réalisation est **découpée en lots ordonnés**, du socle d'infrastructure vers les couches applicatives et analytiques, chaque lot s'appuyant sur le précédent. Ce phasage est une démarche d'ingénierie ; il ne réduit pas le périmètre.

Lot	Composant	Capacités livrées (périmètre complet)
L0	Socle & infrastructure	Cluster Kubernetes multi-tenant, pipeline Kafka, bases de données, hébergement souverain.
L1	Agent universel	Go Windows + Linux, egress-only, buffer hors-ligne, binaires signés, mise à jour sécurisée.

Lot	Composant	Capacités livrées (périmètre complet)
L2	SIEM & corrélation	Wazuh + moteur de corrélation, chaînes d'attaque multi-étapes, cartographie MITRE ATT&CK.;
L3	UEBA & modèles d'IA	UEBA (Isolation Forest + LSTM), Modèle 1 (anomalies réseau), Modèle 2 (fraude interne), scoring par entité.
L4	SOAR	Bibliothèque de playbooks encadrés (seuils, dry-run, rollback, validation humaine).
L5	Portail & restitution	Dashboard web, LLM Analyst, notifications SMS, rapport hebdomadaire, rapports de conformité.
L6	Durcissement & tests	Sécurisation de la plateforme, simulation d'attaques, évaluation chiffrée.

3. Exigences fonctionnelles

3.1 Agent universel léger

- **EF-A1** — Collecter connexions réseau, processus actifs, modifications de fichiers et événements système.
- **EF-A2** — Fonctionner sous Windows et Linux à partir d'un binaire unique (Go).
- **EF-A3** — Transmettre la télémétrie de façon chiffrée (E2EE) en flux sortant uniquement.
- **EF-A4** — Mettre en file d'attente localement et rejouer les données après une coupure réseau (store-and-forward).
- **EF-A5** — Vérifier l'empreinte (hash) des processus contre VirusTotal et un flux de threat intelligence local.
- **EF-A6** — S'enrôler via un jeton d'enrôlement à usage unique (et non un code court devinable).

3.2 Moteur SIEM et corrélation

- **EF-S1** — Centraliser et normaliser les événements de toutes les sources.
- **EF-S2** — Corréler les événements pour reconstituer des chaînes d'attaque multi-étapes.
- **EF-S3** — Associer chaque détection à une ou plusieurs techniques MITRE ATT&CK.;
- **EF-S4** — Générer une alerte unique et enrichie pour une chaîne d'attaque (et non une alerte par événement).

3.3 UEBA (analyse comportementale)

- **EF-U1** — Apprendre le comportement de référence de chaque utilisateur/entité.
- **EF-U2** — Détecter connexions à heures inhabituelles, volumes anormaux, localisations et accès atypiques.
- **EF-U3** — Calculer un score de risque dynamique (0–100) par entité.
- **EF-U4** — Gérer le démarrage à froid via données synthétiques / rejeu de jeux de données publics.

3.4 SOAR (réponse automatisée)

- **EF-R1** — Exécuter des playbooks selon le type d'incident (ex. isolation d'un poste, blocage d'une IP, notification).

- **EF-R2** — Conditionner les actions destructrices à un seuil de confiance et/ou à une validation humaine.
- **EF-R3** — Proposer un mode simulation (dry-run) et la réversibilité (rollback) des actions.
- **EF-R4** — Tracer toute action automatisée dans un journal d'audit.

3.5 Portail client, LLM Analyst et notifications

- **EF-P1** — Afficher un score de sécurité, les incidents actifs, les postes surveillés et un rapport de conformité ISO 27001.
- **EF-P2** — Permettre des actions rapides (isoler un poste, bloquer un site, exporter un rapport).
- **EF-P3** — Expliquer chaque alerte en français clair via un LLM (Mistral/Llama) en mode assistance (RAG) — l'IA explique et résume, elle ne décide jamais.
- **EF-P4** — Envoyer des notifications SMS pour les incidents critiques.
- **EF-P5** — Produire un rapport de sécurité hebdomadaire (synthèse, actions requises, conseil).

4. Exigences non-fonctionnelles

Catégorie	Exigence
Performance	Agent : empreinte cible < 15 Mo, CPU < 0,5 %. Ces valeurs doivent être validées empiriquement , non affirmées.
Sécurité plateforme	La plateforme est une cible de haute valeur : isolation stricte des tenants, gestion centralisée des secrets, binaires d'agent signés, canal de mise à jour sécurisé (anti supply-chain).
Souveraineté	Les données sensibles sont hébergées sur une infrastructure nationale ; aucun stockage de données client sensibles sur un cloud étranger.
Disponibilité / résilience	Tolérance aux coupures réseau (store-and-forward) et aux coupures électriques (arrêt brutal sans corruption). Optimisation de la bande passante.
Scalabilité	Multi-tenant via namespaces Kubernetes et RBAC ; montée en charge horizontale du pipeline.
Utilisabilité	Installation autonome en moins de 10 minutes ; interface compréhensible par un DSI non-technicien.

5. Contraintes

5.1 Contraintes réglementaires

- Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et à la cybercriminalité au Cameroun.
- Régulation et missions de l'ANTIC (Agence Nationale des Technologies de l'Information et de la Communication).
- Alignement sur la norme ISO/IEC 27001 pour la génération des rapports de conformité.
- Régulateurs sectoriels de la cible secondaire : COBAC (supervision des établissements de microfinance dans l'espace CEMAC), code CIMA (assurances), obligations de secret professionnel encadrées par l'ONECCA (cabinets comptables).

5.2 Contraintes techniques et contexte local

- Connectivité intermittente : l'architecture ne doit pas supposer un lien permanent.
- Instabilité électrique : tolérance aux arrêts brutaux.
- Coût et rareté de la bande passante : compression et collecteur local optionnel.
- Threat intelligence locale (IOC régionaux) en complément des sources génériques.

5.3 Contraintes juridiques (surveillance des employés)

L'analyse comportementale (UEBA) constitue un profilage des employés. Le déploiement doit reposer sur une base légale claire (information préalable, finalité de sécurité, proportionnalité) et respecter la protection des données personnelles. Ce point fera l'objet d'une section dédiée dans le rapport.

6. Stack technique

Brique	Technologie
Agent	Go (multiplateforme, léger)
SIEM	Wazuh + moteur de corrélation Python
UEBA / IA	Isolation Forest, LSTM (PyTorch)
SOAR	Shuffle Automation + playbooks Python
Pipeline	Apache Kafka (streaming temps réel)
Stockage chaud	Elasticsearch (logs récents)
Stockage froid	Archivage souverain chiffré
Base relationnelle	PostgreSQL (config, users, tenants)
Séries temporelles	TimescaleDB (métriques comportementales)
Backend API	FastAPI (Python)
Frontend	React.js + Recharts
Assistant	LLM Mistral/Llama (RAG)
Notifications	Passerelle SMS + WhatsApp Business API
Infrastructure	Kubernetes + Helm + Terraform + GitLab CI/CD
Supervision	Prometheus + Grafana

7. Modèles d'intelligence artificielle

7.1 Modèle 1 — Détection d'anomalies réseau (socle technique)

Apprentissage du trafic réseau normal puis détection des écarts (volume sortant anormal, connexions vers IP/pays inhabituels, protocoles atypiques tels que tunneling DNS, scan de ports interne, communication C2). Approche : Isolation Forest ou autoencodeur.

Jeux de données : CICIDS2017 / CSE-CIC-IDS2018 (référence moderne labellisée), CTU-13 (trafic botnet/C2), UNSW-NB15, NSL-KDD. Données publiques et documentées — le modèle est entraîné sur

ces benchmarks puis ré-entraînable sur les données locales après déploiement.

7.2 Modèle 2 — Détection comportementale de fraude interne

Détection d'anomalies sur logs structurés (et non du NLP) : modifications inhabituelles de montants, création massive de comptes (fonctionnaires fantômes), exports massifs de données sensibles. Composant à part entière, le Modèle 2 répond directement au risque majeur de la cible principale : la fraude interne dans les administrations (faux mandatements, fonctionnaires fantômes, exfiltration de données fiscales).

Jeux de données : CERT Insider Threat (CMU/SEI, référence mondiale) complété par des données synthétiques de type SIGIPES/SYDONIA. Le recours à des données synthétiques n'est pas un choix de réduction de périmètre mais une **contrainte de disponibilité** : aucune donnée de fraude réelle et étiquetée n'est publiquement accessible. Cette limite est documentée, et un ré-entraînement sur données de terrain est prévu après déploiement chez le client.

7.3 LLM Analyst (sans entraînement)

Le LLM n'est pas entraîné : il est guidé par prompting et RAG pour expliquer les alertes en français. Il assiste l'utilisateur sans jamais prendre de décision de sécurité.

8. Modèle économique

Deux logiques tarifaires coexistent, alignées sur les deux cibles et leurs modes d'achat respectifs.

8.1 Abonnement mensuel — secteur financier non bancaire (cible secondaire)

Offre	Cible	Tarif
Starter	< 10 postes	25 000 FCFA / mois
Business	< 50 postes	75 000 FCFA / mois
Enterprise	< 200 postes	200 000 FCFA / mois

8.2 Contrat public — administrations (cible principale)

Les administrations s'engagent via la commande publique : **contrat annuel** (et non abonnement mensuel), passé par appel d'offres, intégrant l'**hébergement souverain** — voire un déploiement on-premise pour les données les plus sensibles — ainsi qu'un volet d'accompagnement et de conformité. Le cycle de vente est long et le prix n'est pas l'argument déterminant : la souveraineté, la conformité réglementaire et l'accompagnement le sont.

8.3 Positionnement et séquencement

Comparaison : recruter un analyste SOC ≈ 500 000 FCFA/mois ; solution étrangère (CrowdStrike, SentinelOne) ≈ 50 000 \$/an. **Positionnement honnête** : automation-first avec escalade humaine — l'automatisation traite le volume, un humain intervient sur les cas complexes. **Séquencement** : le secteur financier non bancaire, à cycle de vente court, génère du chiffre d'affaires rapidement et finance la maturation des contrats publics, structurellement plus longs à conclure.

9. Critères d'acceptation et d'évaluation

La validation s'appuie sur une méthodologie chiffrée et reproductible :

- Couverture des détections cartographiée sur le référentiel MITRE ATT&CK.;
- Métriques mesurées : taux de détection, taux de faux positifs, MTTD (temps moyen de détection), MTTR (temps moyen de réponse).
- Validation empirique de l'empreinte de l'agent (CPU, mémoire, réseau).
- Simulation d'attaques via MITRE Caldera et Atomic Red Team pour démontrer les détections en conditions contrôlées.

10. Livrables et planning

- Code source de l'agent, du pipeline, des règles de corrélation et des playbooks.
- Modèle d'IA entraîné (Modèle 1) avec rapport d'évaluation.
- Portail web de démonstration.
- Documentation technique et cahier des charges.
- Rapport de stage et support de soutenance.

Le calendrier détaillé est fourni dans le planning prévisionnel (diagramme de Gantt) joint au dossier.

11. Risques et hypothèses

Risque	Mitigation
Charge de réalisation élevée (périmètre complet)	Découpage en lots ordonnés, phasage de la réalisation et priorisation des lots du socle vers les couches hautes.
Indisponibilité de données locales (MINFI)	Recours aux jeux de données publics + données synthétiques assumées.
Faux positifs des actions automatiques	Seuils de confiance, dry-run, validation humaine, rollback.
Compromission de la plateforme elle-même	Isolation tenants, secrets, signature des agents, MAJ sécurisée.
Connectivité instable sur site	Store-and-forward et collecteur local optionnel.